

Deliberation SAN-2023-009 of June 15, 2023

National Commission for Information Technology and Liberties

Nature of the deliberation: Sanction

Legal status: In force

Date of publication on Légifrance: Thursday, June 22, 2023

Deliberation of the restricted formation No. SAN-2023-009 of June 15, 2023, concerning the company CRITEO

The National Commission for Information Technology and Liberties, convened in its restricted formation composed of Mr. Alexandre LINDEN, president, Ms. Christine MAUGÜÉ, and Messrs. Alain DRU and Bertrand du MARAIS, members;

Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data;

Considering Directive 2002/58/EC of the European Parliament and of the Council of July 12, 2002, concerning the processing of personal data and the protection of privacy in the electronic communications sector;

Considering Law No. 78-17 of January 6, 1978, relating to data processing, files, and freedoms, notably its Articles 20 and following;

Considering Decree No. 2019-536 of May 29, 2019, taken for the application of Law No. 78-17 of January 6, 1978, relating to data processing, files, and freedoms;

Considering Deliberation No. 2013-175 of July 4, 2013, adopting the internal regulations of the National Commission for Information Technology and Liberties;

Considering Decision No. 2020-005C of December 27, 2019, of the president of the National Commission for Information Technology and Liberties, charging the Secretary General to carry out or have carried out a verification mission of the processing operations implemented by the company CRITEO or on its behalf, in any location likely to be concerned by their implementation;

Considering the decision of the president of the National Commission for Information Technology and Liberties designating a rapporteur before the restricted formation, dated June 23, 2021;

Considering the report of Mr. François PELLEGRINI, rapporteur commissioner, notified to the company CRITEO on August 3, 2022;

Considering the written observations submitted by the counsel of the company CRITEO on October 31, 2022;

Considering the rapporteur's response to these observations notified to the company CRITEO on December 7, 2022;

Considering the new written observations submitted by the counsel of the company CRITEO, received on January 30, 2023;

Considering the oral observations made during the session of the restricted formation;

Considering the other documents in the file;

Present at the session of the restricted formation on March 16, 2023:

- Mr. François PELLEGRINI, commissioner, heard in his report;

As representatives of the company CRITEO:

- [...]

By videoconference: [...]

The company CRITEO having spoken last;

The restricted formation adopted the following decision:

I. Facts and Procedure

1. Founded in 2005 in France, the company CRITEO SA (hereinafter referred to as the "company") specializes in displaying targeted advertisements on the web. In 2022, the CRITEO group employed approximately 3,000 employees and achieved a total revenue of approximately 1.9 billion euros with a net profit of about 10 million euros.

2. The company implements data processing known as "advertising retargeting," which involves tracking the browsing habits of internet users to display personalized advertisements to them, using cookies placed on users' devices.
3. On November 8, 2018, the National Commission for Information Technology and Liberties (hereinafter "the CNIL" or "the Commission") received a complaint from the association "Privacy International," which notably pointed out that the company was not processing users' data in accordance with the principles set out in Article 5, paragraph 1, of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (hereinafter "the GDPR").
4. On April 4 December 2018, the CNIL was seized of a complaint addressed by the association "None of Your Business" (hereinafter "NOYB") mandated by [...], which denounced the formalism imposed by the company from which the complainant wished to withdraw their consent and oppose the processing of their data (hereinafter "the complainant"). The complainant stated that, despite sending an email to the company in this regard, the latter redirected them to various online procedures dedicated to the exercise of rights.
5. On January 14, 2019, in accordance with Article 56 of the GDPR, the CNIL informed all European supervisory authorities of its competence to act as the lead supervisory authority regarding cross-border processing carried out by the company, a competence derived from the fact that the company's main establishment is located in France.
6. After exchanges between data protection authorities, it became clear that all European authorities are concerned within the meaning of Article 4, 22) of the GDPR.
7. As part of the investigation of the complaint filed by the NOYB association, the CNIL questioned the company about the follow-up given to the complainant's requests. This investigation led to an exchange of letters between the CNIL and the company, dated March 27, April 29, September 9, October 9, December 27, 2019, and February 17, 2020. A meeting was also held on January 17, 2020.
8. Following this investigation and in application of Decision No. 2020-005C of December 27, 2019, by the President of the Commission, a delegation from the CNIL conducted several checks with the company to verify compliance with the provisions of Law No. 78-17 of January 6, 1978, as amended, relating to data processing, files, and freedoms (hereinafter "the Data Protection Act" or "Law of January 6, 1978") and the GDPR.
9. Thus, on January 29, 2020, the delegation sent a questionnaire to the company, to which the latter responded on March 27, 2020, concerning its organization, the personal data processing it implements, its qualification as a data controller, its relationships with its clients and partners, and its management of requests to exercise rights.
10. On September 16 and 17, 2020, the delegation conducted an on-site inspection at the company's premises, during which it notably carried out checks on the websites of two of the company's partners. The delegation also verified the follow-up given to the complainant's request to exercise their rights and obtained information on the modalities for implementing the right to withdraw consent and the right to erasure. The on-site inspection resulted in two reports No. 2020-005/1 and 2020-005/2, notified to the company on September 30, 2020.
11. On October 13, 2020, based on a list provided by the company of the hundred websites from which it collects the most data, the delegation conducted an online inspection of several of these sites to verify, in particular, the modalities for depositing the Criteo cookie in users' terminals and the mechanism implemented to collect their consent. The online inspection resulted in report No. 2020-005/3, notified to the company on October 14, 2020.
12. On June 23, 2021, based on Article 22 of the Law of January 6, 1978, the President of the Commission appointed Mr. François PELLEGRINI as the rapporteur for the purpose of investigating

these elements.

13. On June 9, 2022, the rapporteur sent a supplementary request to the company to obtain, in particular, the latest versions of the general terms and conditions of use of Criteo services, as well as a recent sample of contracts concluded by the company with its partners. The company responded on June 17, 2022.

14. On August 3, 2022, at the conclusion of his investigation, the rapporteur notified the company of a report detailing the breaches of Articles 7, 12, 13, 15, 17, and 26 of the GDPR that he deemed constituted in this case.

15. This report proposed to the restricted formation of the Commission to impose an administrative fine on the company in an amount not less than sixty million euros. It also proposed that this decision be made public and that it no longer allow for the identification of the company by name after a period of two years from its publication.

16. On October 31, 2022, the company submitted observations in response to the rapporteur's report.

17. On December 7, 2022, the rapporteur responded to the company's observations.

18. On January 30, 2023, the company presented new observations in response to those of the rapporteur.

19. By letter dated February 21, 2023, the rapporteur informed the company's counsel that the investigation was closed, in accordance with Article 40, III, of Decree No. 2019-536 of May 29, 2019, implementing the Data Protection Act.

20. The rapporteur and the company presented oral observations during the session of the restricted formation on March 16, 2023.

II. Reasons for the Decision

A. On the European Cooperation Procedure

21. In accordance with Article 60, paragraph 3 of the GDPR, the draft decision adopted by the restricted formation was transmitted on May 16, 2023, to the concerned European supervisory authorities.

22. As of June 13, 2023, none of the concerned supervisory authorities had raised any relevant and reasoned objections to this draft decision, so that, in accordance with Article 60, paragraph 6, of the GDPR, they are deemed to have approved it.

B. On the processing in question, the qualification of personal data, and the responsibility for processing.

1. On the processing in question aimed at displaying personalized advertising

23. Article 4, 2) of the GDPR defines processing as "any operation or any set of operations carried out or not using automated processes and applied to personal data or sets of personal data, such as collection, recording, organization, structuring, storage, adaptation or modification, extraction, consultation, use, communication by transmission, dissemination or any other form of making available, reconciliation or interconnection, limitation, erasure or destruction.

24. In this case, the restricted formation notes that the company implements a data processing referred to as "retargeting" for the purpose of displaying personalized advertising (hereinafter referred to as the "processing in question").

25. Specifically, the company collects the browsing data of internet users through cookies that are placed on their devices when they visit one of the sites of their [...] partners, including publishers and advertisers. When an internet user visits a partner's website, the company registers a cookie in the user's browser terminal, which is assigned a unique identifier, called Criteo ID, that will allow it to

recognize the user during their future visits to other partner sites.

26. Thus, when an internet user visits the website of a partner advertiser, the company records in its database the actions of the user via the cookie (for example, visiting the homepage, logging into a user account, clicking on a "product" page, adding an item to the shopping cart).

27. Then, when the internet user visits the website of a partner publisher, the publisher sends a request to the company to transmit information such as the size of the advertising slot, the nature of the publisher's site, as well as an identifier that allows the company to recognize the user.

28. The company then uses its data processing technologies to determine which advertisement would be the most relevant to display to the user based on their browsing habits and the products or services that may interest them. Based on this analysis, the company then participates in a real-time auction ("real-time bidding" or "RTB") for the display of an advertisement in the publisher's advertising space. If the company wins the auction, the advertisement banner of an advertiser is displayed in the available slot on the publisher's website.

29. Thus, as an intermediary between advertisers and website publishers, the company helps, on the one hand, advertisers reach their target audience with more relevant advertisements, and on the other hand, publishers to monetize their advertising spaces.

30. The restricted formation notes that the company acknowledges implementing the processing described in the preceding paragraphs.

2. On the qualification of personal data of the data processed by the company CRITEO

31. Article 4, 1) of the GDPR defines personal data as "any information relating to an identified or identifiable natural person (hereinafter referred to as the 'data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person."

32. Recital 30 of the GDPR, which is part of a well-established case law of the Court of Justice of the European Union (CJEU, Nov. 24, 2011, Scarlet Extended SA C 70/10, para. 51 and Oct. 19, 2016, Breyer, C-582/14), provides that an online identifier associated with a natural person, such as an IP address or a connection cookie, can "leave traces which, in particular when combined with unique identifiers and other information received by servers, can be used to create profiles of natural persons and identify those persons."

33. In its aforementioned Breyer ruling, rendered under the directive 95/46/EC, the CJEU emphasized the importance of a case-by-case approach to the identifying nature of data rather than a general and principled position. It indicated that, to determine whether a person is identifiable, it is necessary to consider all means that could reasonably be used, either by the data controller or by another person, to identify that person.

34. The rapporteur considers that the company processes personal data, given that in light of the number and diversity of the data collected and the fact that they are all linked to an identifier, it is possible, with reasonable means, to re-identify the natural persons to whom this data relates.

35. The company believes that it processes "browsing events," which are pseudonymized technical data that do not allow it to directly identify the internet users to whom they are attached. It argues that it only recognizes the identity of a person in the event of a request for access rights where it can match the Criteo cookie identifier (Criteo ID) with the identity of the natural person. Outside of such a scenario, it believes that the risk of re-identification is very low and produces simulations conducted by providers on this point.

36. It concludes that since it only processes pseudonymized data, any potential breaches it may have committed have had a very limited impact on the individuals concerned, which the restricted formation should take into account in its

****Assessment.****

37. The restricted formation recalls that only true anonymization of the processed data, which would strip the data of its "personal" nature, meaning without the possibility of re-identifying the natural person to whom it relates, would exempt the processing from all the requirements of the GDPR.

38. In this case, the restricted formation notes that while the company does not claim to process anonymized data, it asserts that it only processes pseudonymized data that presents a very low risk of re-identification.

39. The restricted formation also notes that the Criteo ID cookie identifier, assigned by the company through the cookies it places, aims to distinguish each individual from whom it collects data and that numerous pieces of information intended to enrich the advertising profile of the internet user are associated with this identifier, including:

- data related to the identification of the person: geographical location from IP address, Criteo user identifier, terminal identifier, identifiers provided by partners, hashed email address provided by partners;
- data related to the activity of the person, which corresponds to tracking the browsing history of the internet user across the visited sites, the products viewed, those added to the cart, as well as the act of purchase. This also includes any interactions of the user with the advertisements presented to them (did the user click on the banner? did they make a purchase?);
- derived or inferred data from the previous information in order to propose to the user the most relevant products, considering their interests.

40. Thus, the restricted formation notes that while the company does not directly possess the identity of the natural persons to whom the terminals on which cookies are registered are linked, re-identification can be facilitated by the fact that, in certain cases, the company collects, in addition to the data related to browsing events, other data that facilitate re-identification such as the email addresses of persons who have navigated from an authenticated (or "logged") environment in hashed form, corresponding identifiers generated by other actors, the IP address in hashed form, or even the user agent of the terminal used.

41. Consequently, as long as the company is able to re-identify individuals by reasonable means, the processed data retains a personal nature, within the meaning of Article 4, 1) of the GDPR.

42. It follows that the GDPR is applicable and, in light of what has been indicated above, the company is responsible for the processing in question.

****C. On the failure to demonstrate that the data subject has given consent****

43. Under Article 6, paragraph 1, of the GDPR: "Processing shall be lawful only if and to the extent that at least one of the following applies:

- a) the data subject has given consent to the processing of their personal data for one or more specific purposes;
- b) the processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;
- c) the processing is necessary for compliance with a legal obligation to which the controller is subject;
- d) the processing is necessary to protect the vital interests of the data subject or of another natural person;
- e) the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;
- f) the processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular when the data subject is a child.

The point f) of the first paragraph does not apply to processing carried out by public authorities in the performance of their tasks."

44. Pursuant to Article 4, 11) of the GDPR, consent is defined as "any freely given, specific, informed and unambiguous indication of the data subject's wishes by which they, by a statement or by a clear affirmative action, signify agreement to the processing of personal data relating to them."

45. Article 7, paragraph 1, of the GDPR regarding the conditions for consent states: "Where the

processing is based on consent, the controller shall be able to demonstrate that the data subject has given consent to the processing of personal data relating to them."

46. The rapporteur considers that the company has not implemented any measures to ensure that the personal data it processes are only those for which valid consent from the data subject has been obtained. He notes that among the websites monitored by the CNIL, more than half of the sites published by its partners did not obtain valid consent and that the company had not implemented an audit mechanism for its partners.

47. The company, invoking the Fashion ID ruling (CJEU, July 29, 2019, C 40/17), argues that its partners, who are joint controllers, are best positioned to collect the consent of the data subjects since the Criteo cookie is placed on the users' terminals while browsing their website.

48. The company adds that in this respect, the various agreements concluded with its partners... ensure that they have obtained the necessary consent from users for the placement of cookies and the subsequent processing of personal data.⁶¹ The restricted formation emphasizes that this contractual arrangement is crucial for ensuring compliance with the GDPR, particularly in the context of joint processing responsibilities.⁶² It notes that the partners must clearly communicate their respective roles and obligations regarding data processing to ensure that users' rights are respected and that they have a legal basis for their processing activities.⁶³ Furthermore, the restricted formation highlights that the partners must implement adequate measures to demonstrate compliance with the GDPR, including maintaining records of consent and ensuring transparency in their data processing practices.⁶⁴ In conclusion, the restricted formation reiterates the importance of a clear and effective contractual framework between the parties involved in joint processing to uphold the principles of the GDPR and protect the rights of data subjects.

****Collecting the consent of the data subject****

for subsequent processing carried out based on the data collected by this cookie.⁶¹ The restricted formation, however, believes that the fact that the collection of consent from internet users for the implementation of the processing in question falls to the partners does not exempt the company from its obligation, under Article 7 of the GDPR, to be able to demonstrate that the data subject has given their consent.⁶² This dual regime of responsibility ensures that at all stages of the processing of data collected during a user's navigation on one of the company's partner sites, each joint data controller complies with the obligations incumbent upon them: for the partners, those related to the deposit and reading of the Criteo cookie on the user's terminal, and for the company, those related to subsequent processing carried out based on the data collected through this cookie.⁶³ It is indeed necessary that the data subjects effectively benefit from the protection offered by the applicable texts to which they are entitled throughout their navigation and, in particular, that their data is processed by the company only if they have previously and validly consented.⁶⁴ Furthermore, the core business of the company consists of transforming raw navigation data into valuable information that it exploits. Since the company plays a central role in the advertising ecosystem, it must all the more be able to ensure that the

processing in question complies with the regulations in force.⁶⁵ Finally, the restricted formation notes that the Fashion ID ruling, cited by the company, concerns the question of who, between the site manager (the company Fashion ID) or the cookie publisher (the company Facebook), should collect the consent of the data subjects before depositing the cookie published by Facebook, and that it was rendered under the aegis of Directive 95/46/EC on data protection.⁶⁶ To the extent that the European legislator intended to strengthen the rights of individuals and the accountability of actors by establishing, in particular, the obligation for the data controller to be able to demonstrate that the person whose data is being processed has effectively given their consent, under Article 7, paragraph 1, of the GDPR, the restricted formation believes that the reference to the Fashion ID ruling is not relevant in this case.⁶⁷ Secondly, the restricted formation notes that during the online verifications conducted during the on-site inspection on September 16, 2020, and during the online inspection on October 13, 2020, the delegation found on seven partner websites of the company that a Criteo cookie had been deposited in the terminal used on that occasion, as soon as it arrived on the homepage without the user having executed any action, and this while at the time of these findings, the CNIL had already had the opportunity to remind that such practices directly contravene the provisions of the Informatique et Libertés law applicable to cookies.⁶⁸ The restricted formation further notes that in three cases, the visited site did not allow the user to refuse cookies other than by configuring their browser, which does not constitute a valid consent refusal mechanism, while in two cases, a Criteo cookie was deposited after the delegation had expressed its refusal to this deposit.⁶⁹ Moreover, during the on-site inspection on September 16, 2020, the delegation found that the two visited sites did not contain any mechanism allowing for the collection of consent for the deposit of cookies, such as a button or a checkbox. Several events related to the navigation of these two sites were recorded in the company's database, such as the visit of product pages. sold by the partners of the company. ⁷⁰ It emerges from all these verifications that the absence of valid consent collection was observed by the delegation at nearly one in two visited sites. However, the restricted formation also notes that nine of the twelve sites visited by the CNIL services were indicated by the company itself as those generating the most data collected in its database. ⁷¹ While it is true that the control procedure did not allow for the verification of all the sites of the company's partners, the

restricted formation considers that it can be reasonably inferred from the aforementioned findings that at the time of the controls, the company was processing a significant volume of browsing data for which internet users had not given valid consent. 72. Thirdly, the restricted formation notes that at the time the control procedure was initiated, the company had not implemented any satisfactory measures to consider itself compliant with the requirements of Article 7, paragraph 1, of the GDPR. 73. Thus, the restricted formation points out that at the beginning of the control procedure, in response to the delegation's question aimed at understanding the measures put in place by the company to ensure the validity of consent, in the event that it had to delegate the collection of this consent to a third party, the latter had limited itself to reproducing a mention from its general terms of use, in their applicable version from May 2016, according to which the company required its partners, "when the law provides for it," that the privacy policy of their site include "mentions and choice mechanisms compliant with applicable laws and regulations." 74. However, the restricted formation considers that such a clause alone did not guarantee the existence of valid consent and that it was at least necessary for it to be supplemented to specify that the organization collecting the consent must provide the other party with proof of consent, so that each data controller wishing to rely on it can effectively state it. 75. In this case, the restricted formation notes that at the time of the initiation of the control procedure, this clause was not only not supplemented by a specific clause regarding proof of consent, but also that the company had admitted that it had never terminated a contract due to a partner's failure to comply with its contractual obligations, nor implemented any other control measures regarding its partners. 76. In this sense, the restricted formation notes that the various measures put forward by the company were only gradually deployed starting in 2020, after the initiation of the control procedure in January 2020. 77. The restricted formation thus takes note of the audit campaign conducted by the company with its partners since 2020 and the fact that the company has also terminated the contract with one of them who did not comply with its obligations regarding cookies. 78. It also notes that in subsequent versions of its general terms of use, the company included a clause regarding proof of consent whereby the partner agrees to "promptly provide Criteo, upon request and at any time, proof that consent from the data subject has been obtained by the partner." 79. In light of these elements, the restricted formation considers that the company has come into compliance with the requirements of Article 7, paragraph 1, of the GDPR. 80. It nevertheless emphasizes that this late compliance does not affect the fact that the company processed the personal data of internet users without being able to demonstrate that they had validly consented to the processing aimed at displaying personalized advertising, in violation of Article 7, paragraph 1, of the GDPR.

On the failure to comply with information and transparency obligations

81. Article 12, paragraph 1, of the GDPR states that: "The data controller shall take appropriate measures to provide any information referred to in Articles 13 and 14 as well as to carry out any communication under Articles 15 to 22 and Article 34 regarding the processing to the data subject in a concise, transparent, intelligible and easily accessible form, using clear and plain language, particularly when providing information specifically addressed to a child. The information shall be provided in writing or by other means, including, where appropriate, by electronic means."

82. Under Article 13 of the GDPR, the data controller must provide the data subject with the following information: "a) the identity and contact details of the data controller and, where applicable, of the data controller's representative; b) where applicable, the contact details of the data protection officer; c) the purposes of the processing for which the personal data are intended as well as the legal basis for the processing; d) where the processing is based on Article 6, paragraph 1, point f), the legitimate interests pursued by the data controller or by a third party; e) the recipients or categories of recipients of the personal data, if any; and f) where applicable, the fact that the data controller intends to transfer personal data to a third country or to an international organization, and the existence or absence of an adequacy decision by the Commission or, in the case of transfers referred to in Articles 46 or 47, or Article 49, paragraph 1, second subparagraph, the reference to appropriate or suitable safeguards and the means of obtaining a copy or the place where they have been made available."

83. In this case, the rapporteur argues that the information provided by the company to the data subjects was not complete in that it did not inform all the purposes related to the processing in question in the version of its privacy policy applicable at the date of the findings, notably the purpose related to

the improvement of its technologies.

84. The rapporteur also criticizes a lack of clarity regarding the legal basis of consent applicable to the processing, which the company specified varies depending on the country, and regarding the purposes implemented on the basis of legitimate interest.

85. The company responds that it has updated its privacy policy.

86. It contests in any case the first complaint, considering that it did not have to specify the purpose of improving its technologies since, according to it, this purpose includes technical elements that generally contribute to the same purpose as the display of personalized advertisements.

87. On the second complaint, it argues that any ambiguities pointed out by the rapporteur never prevented the data subjects from exercising their rights.

88. In its second observations, the company argues that no failure on its part to comply with the obligations arising from Article 13 of the GDPR can be attributed to it as it would only be carrying out indirect collection of data.

89. The restricted formation recalls, firstly, that the GDPR distinguishes the regime of the obligation to provide information that applies to the data controller depending on the nature of the data collection: the data controller is subject to the provisions of Article 13 of the GDPR when the data is collected directly from the data subject and to the provisions of Article 14 of the GDPR in the opposite case.

90. It adds that in point 26 of its guidelines of November 29, 2017, on transparency, in their revised version of April 11, 2018, the EDPB recalls that Article 13 of the GDPR

policy, but it is essential to assess whether these changes effectively address the concerns raised.¹⁰⁰ The restricted formation emphasizes that the clarity and transparency of the information provided to users are crucial for ensuring that they can exercise their rights under the GDPR, particularly their right to consent and their right to object.¹⁰¹ Consequently, the restricted formation concludes that the company must ensure that its data processing practices are compliant with the GDPR, particularly regarding the collection of personal data and the legal bases for such processing.¹⁰² The restricted formation also notes that any updates to the privacy policy must be communicated effectively to users, ensuring that they are fully informed of their rights and the implications of their consent.¹⁰³ Finally, the restricted formation reiterates that the company must take appropriate measures to ensure that its partners also comply with GDPR requirements, particularly in relation to the integration of data protection policies on their websites.

****Privacy Policy****, insofar as it now specifies that consent applies to individuals residing in the European Economic Area and includes a table summarizing all the purposes of its processing, including those based on the legal basis of legitimate interest, which includes a detailed description of these purposes and the categories of data concerned. The restricted formation observes that the company has also resolved the contradiction noted above.

100. Thirdly, the restricted formation notes that the section "Purpose of Personal Data Processing" of the company's privacy policy, in its version applicable at the date of the findings, contained only the following line: "Criteo processes your personal data for personalized advertisements."

101. However, during the on-site inspection on September 16 and 17, 2020, the company specified to the delegation that the processing also allowed "to optimize the responses to be given to bids, the selection of items to be presented in an advertisement, and to propose the best layout for this banner."

102. While the restricted formation admits that certain technical operations described by the company directly contribute to the main purpose of displaying personalized advertising, it believes that others serve a distinct purpose.

103. Indeed, the company uses the data collected through cookies to improve its own technologies (a purpose referred to as "machine learning," utilizing the data collected by the company to self-configure algorithmic targeting processes). Thus, the main objective of this subsequent processing aims to enhance the effectiveness of the advertising targeting carried out by Criteo in general. Therefore, this is a distinct purpose that should have been communicated to the individuals concerned.

104. The restricted formation notes that in the new version of its privacy policy, published online on November 4, 2022, the company now clearly distinguishes, within the section "Use of Your Data," on

the one hand, the purpose of "displaying personalized advertising" and, on the other hand, the purpose of "training models," defined as enabling "the improvement of Criteo's advertising operations performance."

105. It follows from the above that by not providing individuals with all the information required, by using terms that are insufficiently clear and precise, and by presenting an erroneous legal basis for the processing, the company has failed to meet its obligations of transparency and information as provided for in Articles 12 and 13 of the GDPR. However, it acknowledges that the company has come into compliance during the present procedure.

****E. On the breach of the obligation to respect the right of access of individuals concerned to their personal data****

106. Article 12, paragraph 1, of the GDPR states that: "The data controller shall take appropriate measures to provide any information referred to in Articles 13 and 14 as well as to carry out any communication under Articles 15 to 22 and Article 34 regarding the processing to the data subject in a concise, transparent, intelligible and easily accessible form, using clear and plain language."

107. Article 15, paragraph 1, of the GDPR provides that: "The data subject has the right to obtain from the controller confirmation as to whether or not personal data concerning them are being processed and, where that is the case, access to the personal data [...]"

108. In this case, in the context of the investigations conducted by the CNIL, the company provided the delegation with three examples of responses sent to individuals who had made access requests.

109. It follows that when a person exercised its right of access, the company transmitted to it the data extracted from the following three tables:

- the table "Advertiser_advent," which stores all data related to advertiser events;
- the table "Banner_display," which stores all data necessary to display an advertisement to the user (for example, the user's country, data related to the advertiser, or the version of the operating system of the user's device);
- the table "Click_cas," which stores all data related to a user's interactions with advertising banners.

110. The rapporteur considers that the company only partially responded to the access requests it received, as it did not communicate the data contained in three other tables:

- the table "Usermatching," which contains information allowing for the reconciliation of Criteo identifiers (in cases where the same user uses multiple devices) in a "deterministic" manner (the company relies on information provided by its partners, such as a loyalty card number, an Apple or Android identifier, and/or a hashed email address to create a link between two Criteo identifiers);
- the table "bc_tcp_timestamp," which contains information allowing for the reconciliation of identifiers in a "probabilistic" manner (the company applies a prediction model based on data related to two identifiers that it believes correspond to the same user);
- the table "Bid_request," which contains information related to events concerning the online bidding protocol.

111. He also estimates that the information provided was not intelligible for the user, as the company only provided a summary description of the purpose of each table without offering explanations regarding the purpose of each of the columns in these tables or their content.

112. The company argues that its procedures in response to access requests comply with the requirements of Article 15 of the GDPR. More specifically, it addresses each of the three tables listed by the rapporteur and explains why, in the case of an access request, it did not communicate the data they contained.

113. Regarding the table "Usermatching," the company claims that it only contains data allowing for the reconciliation of the Criteo identifier with other identifiers, but that it had nonetheless committed to providing this data in its responses to access requests as of November 2022.

114. Regarding the table "bc_tcp_timestamp," the company explains that it relies on a probabilistic method and could potentially reconcile two distinct individuals, such that the communication of the data risks infringing the rights and interests of third parties in the event that data relating to another person were communicated to the requester. For this reason, it excluded this table from its responses to access requests.

115. Regarding the table "bid_request," the company states that it contains approximately 400 fields related to bidding requests, so it essentially consists of technical data, and that the remaining data is identical to that contained in the table "Banner_display," which has already been communicated by the company. However, it specifies that it had committed to providing all of this data in its responses to access requests before March 2023, allowing time to implement an action plan that would enable it to extract this data by profile.

116. On the intelligibility of the information provided to the data subjects, it indicates that it has supplemented the explanations with a table listing, for each table, the nature of the data processed, and providing a description and examples of data, which it transmits in its...

****Response to Access Requests.****

117. The restricted formation acknowledges the explanations provided by the company regarding the "bc_tcp_timestamp" table and indeed considers that the company was not required to disclose the data from this table insofar as it may concern several individuals without the company being able to identify with certainty which data exclusively pertains to the individual making the request.

118. Regarding the "Usermatching" and "bid_request" tables, it considers that the elements put forward and produced by the company now allow the user to better understand the information transmitted to them.

119. However, the restricted formation notes that the explanations provided by the company do not justify, as of the date of the findings, the non-disclosure of the data contained in these two tables, whereas it is undisputed that these tables contain personal data that can be combined with other data recorded by the company and, in particular, with the identifier assigned to each internet user.

120. It adds that it follows from these same findings that, in its response to access rights requests, the company succinctly explained the purpose of each table in one sentence and invited users to send an email to obtain further information. Thus, in the absence of systematic communication of information regarding the purpose and content of each of the columns in these tables, the company placed the user in uncertainty regarding the nature of the data processed concerning them.

121. It follows from the above that by not disclosing the entirety of the personal data of individuals exercising their right of access to it and by not proactively providing them with documentation to help them understand the data communicated to them, the company failed to meet its obligations under Articles 12 and 15 of the GDPR.

****On the Breach of the Obligation to Respect the Right to Withdraw Consent and to Erase Data****

122. Article 7, paragraph 3, of the GDPR states: "The data subject has the right to withdraw their consent at any time. The withdrawal of consent does not affect the lawfulness of processing based on consent before its withdrawal. The data subject is informed of this before giving their consent. It is as easy to withdraw as it is to give consent."

123. Under Article 17, paragraph 1, of the GDPR, "The data subject has the right to obtain from the controller the erasure, without undue delay, of personal data concerning them and the controller has the obligation to erase such personal data without undue delay, when one of the following grounds applies: [...] b) the data subject withdraws consent on which the processing is based, in accordance with Article 6, paragraph 1, point a), or Article 9, paragraph 2, point a), and there is no other legal ground for the processing [...] d) the personal data have been unlawfully processed [...]".

124. In this case, exchanges took place between the CNIL services and the company following the receipt of the complaint from [...] regarding their individual situation but also more generally, the procedures implemented by the company to respond to requests for the exercise of individuals' rights. The company indicated that it had evolved the measures implemented, notably to make effective the right to withdraw consent and the right to erasure of data.

125. It follows from the investigations subsequent to these exchanges and the deployment of the measures announced by the company that the individuals concerned who wished to withdraw their consent to the processing of their data by the company or who exercised their right to erasure could do so.

by clicking on the "Disable Criteo services" button accessible in the company's privacy policy found on the "criteo.com" website. The company specified that when a person clicks this button, an "opt-out" cookie is placed in the person's browser, thereby preventing the subsequent placement of Criteo cookies and the display of personalized advertisements. 126. The company clarified that disabling Criteo services, meaning no longer displaying personalized advertisements to the person, could also be done using platforms provided by professional associations representing the sector, such as the "YourOnlineChoices" platform. 127. During the on-site inspection on September 17, 2020, the delegation found that the company no longer retained the user identifier assigned to [...]. During this same inspection, the company stated that the procedure for disabling its services no longer allowed it "to link the concerned user identifier to the user's browser in such a way that no advertisement will be offered to this identifier," without having the effect of deleting the identifier of the user who made the opposition or deletion request from its records. The company added that: "in the event that a user identifier has undergone a deactivation procedure, it will no longer be possible to subsequently reconcile the events related to this identifier with any other potential identifiers related to this user." Finally, the company indicated that it could reuse the Criteo user identifier as well as the events related to the deactivation request for the purpose of improving its technologies. 128. The rapporteur considers that the company does not meet the requirements of Article 17 of the GDPR as it neither deletes the identifier of the person nor erases the related browsing events, whereas the processing of the complaint from [...] demonstrates that it is indeed capable of effectively deleting the data it processes. 129. The company argues that it is not required to carry out such deletion as it would have a legitimate interest in retaining and processing the data of individuals who have made a deletion request for the following six purposes: sales correspondence/attribution, fraud prevention/fraud fighting, model training, billing, reporting, and incident resolution. 130. In this sense, it believes it is justified in not proceeding with the effective deletion of this data as long as the pursuit of these other purposes based on legitimate interest justifies their retention. For each of these six purposes, the company provides a study demonstrating the relevance of relying on this legal basis. 131. Specifically regarding the purpose of model training, the company considers that this allows the concerned individuals to receive even more personalized advertisements, which also falls within their interest. It adds that the CNIL has already recognized, in a sanction deliberation No. 2013-420 of January 3, 2014, and in a decision MED-2017-075 of November 27, 2017, that "the improvement of services" could be considered a legitimate interest of a data controller. 132. The restricted panel notes that when responding to a deletion request, the company limits itself to stopping the display of personalized advertisements on the device of the person who made the request, without proceeding to an effective deletion of the data related to this person. 133. The restricted panel observes that the company claims it cannot proceed with such deletion on the grounds that it needs the data collected as part of its advertising targeting processes, based on consent, to successfully achieve six other purposes which, according to the latter, are based on the legal basis of legitimate interest. 134. However, without it being necessary to rule on the adequacy of legitimate interest as the legal basis for each of the six purposes put forward by the company, the restricted panel considers that, in cases where the company was in any event unable to ensure that the person who made the request had validly consented to the processing of their data by the company, the latter could not continue to process that person's data for subsequent purposes based on the foundation of legitimate interest. However, as demonstrated above, the company retained no evidence of valid consent from individuals, in violation of Article 7 of the GDPR. The company could therefore not limit itself to stopping the display of personalized advertisements and had to proceed with the effective deletion of the processed data. 135. This conclusion is all the more compelling given that investigations revealed that the company processes a significant volume of data for which it has been established that they originated from cookies placed before any expression of will by the internet user and even, in some cases, when the latter expressly indicated their refusal. 136. It follows from the

above that by limiting itself to stopping the display of personalized advertisements and not proceeding with the deletion of personal data in the event of exercising their right to erasure, for individuals for whom the company could not ensure the reality of consent, the company failed to meet its obligations under Articles 7 and 17 of the GDPR. G. On the failure to provide for an agreement between joint controllers of processing 137. Article 26 of the GDPR states that: "1. Joint controllers of processing shall transparently define their respective obligations in order to ensure compliance with the requirements of this regulation, in particular regarding the exercise of the rights of the data subject, and their respective obligations concerning the communication of the information referred to in Articles 13 and 14, by way of an agreement between them. 2. The agreement referred to in paragraph 1 duly reflects the respective roles of the joint controllers of processing and their relationships with the data subjects." 138. The rapporteur notes that at the time of the findings, the company had indeed concluded with its partners, joint controllers of processing (advertisers, publishers, and online auction platforms), a contract that contained a description of the processing activities subject to joint responsibility and the role of each controller with respect to these processing activities. 139. However, he emphasizes that this agreement did not allow for a conclusion regarding the company's compliance with Article 26 of the GDPR. 140. The company argues that, as drafted, the agreement concluded with its partners did not harm the data subjects who benefited from the full protection of the GDPR since the general terms of use of its services provide that partners must provide a link to Criteo's privacy policy and allow data subjects to express their consent to targeted advertising. 141. Nevertheless, it justifies having established a new agreement that came into effect on July 5, 2022. 142. The restricted panel considers that it follows from the wording of Article 35 of the GDPR that the act of distributing the obligations of the joint controllers of processing must cover all obligations provided for by the GDPR in order to determine, for each of these obligations, which of the joint controllers of processing will be responsible for it. 143. In this case, the restricted panel notes that at the time of the findings, the agreement concluded by the company with its partners did not specify certain respective obligations of the controllers.

treatments in relation to requirements contained in the GDPR, such as the exercise by data subjects of their rights, the obligation to notify a data breach to the supervisory authority and to the data subjects, or, where applicable, the carrying out of a data protection impact assessment under Article 35 of the GDPR. 144. It notes that the obligation to conclude an agreement in the case of joint liability is a specific obligation imposed on joint controllers under Article 26 of the GDPR. 145. If, in its version of July 5, 2022, the agreement concluded by the company with its partners now includes the expected mentions under this provision, the restricted formation notes that this late compliance does not call into question the characterization of the breach for the past. 146. It follows from the above that the company failed to fulfill its obligation under Article 26 of the GDPR.

III. On the imposition of corrective measures and publicity 147. Article 20 of Law No. 78-17 of January 6, 1978, as amended, provides that: "when the data controller or its processor does not comply with the obligations arising from Regulation (EU) 2016/679 of April 27, 2016, or from this law, the president of the National Commission for Computing and Liberties may [...] refer the restricted formation of the commission for the imposition, after adversarial proceedings, of one or more of the following measures: [...] 7° Except in cases where the processing is carried out by the State, an administrative fine not exceeding 10 million euros or, in the case of a company, 2% of the total global annual turnover of the previous financial year, the higher amount being retained. In the cases mentioned in paragraphs 5 and 6 of Article 83 of Regulation (EU) 2016/679 of April 27, 2016, these ceilings are raised, respectively, to 20 million euros and 4% of said turnover. The restricted formation takes into account, in determining the amount of the fine, the criteria specified in the same Article 83." 148. Article 83 of the GDPR, as referred to by Article 20, paragraph III, of the Data Protection Act, provides that: "Each supervisory authority ensures that the administrative fines imposed under this article for violations of this regulation referred to in paragraphs 4, 5, and 6 are, in each case, effective, proportionate, and dissuasive," before specifying the elements to be taken into account to decide whether to impose an administrative fine and to determine the amount of that fine.

A. On the imposition of an administrative fine and its amount 149. The company first argues that the

CNIL has violated the principle of non-discrimination by only initiating proceedings against it, despite having established that the websites of its partners did not comply with the regulations applicable to cookies. 150. It further argues that it should not be sanctioned for failing to ensure that its partners obtain valid consent other than through contractual means, as these verifications should actually fall to the CNIL, which would thus be "privatizing" its missions. 151. The company believes that a better consideration of the criteria set out in Article 83, paragraph 2, of the GDPR, particularly regarding the absence of evidence of damage, the non-deliberate nature of the breaches, the measures taken to mitigate the damage, the cooperation it claims to have shown with the supervisory authority, and the categories of personal data concerned, which present low intrusiveness, would justify that, in the event that the restricted formation decides to impose a fine, it significantly reduces the amount of 60 million euros proposed by the rapporteur. 152. It argues that the rapporteur's proposed fine represents 50% of its profit and nearly 3% of its global turnover, which is close to the legal maximum provided for in Article 83 of the GDPR. By comparison, it highlights previous decisions issued by the CNIL against Google (CNIL, FR, December 31, 2021, sanction deliberation No. SAN-2021-023) and Facebook (CNIL, FR, December 31, 2021, sanction deliberation No. SAN-2021-024) regarding cookies, whose amounts reached 0.07% and 0.06% of their total global turnover, respectively. 153. The restricted formation recalls, as a preliminary point, that it is not for the restricted formation to assess the decision of the president of the CNIL to initiate proceedings against the sole company. 154. The restricted formation recalls that to evaluate the appropriateness of imposing a fine and determining its amount, it must take into account the criteria specified in Article 83 of the GDPR, such as the nature, severity, and duration of the violation, the number of persons concerned, the measures taken by the data controller to mitigate the damage suffered by the data subjects, the degree of cooperation with the supervisory authority, the categories of personal data concerned by the violation, and the financial benefits obtained from the breach. 155. Firstly, regarding the imposition of an administrative fine, the restricted formation considers that it is appropriate to first apply the criterion provided for in paragraph a) of Article 83, paragraph 2, of the GDPR relating to the severity of the breach, taking into account the nature, scope of the processing, and the number of persons concerned by it. 156. It first recalls that it has been established that the company was unable to demonstrate that the data subjects had given their consent to the processing of personal data concerning them and that the findings of the control delegation have...

highlighted that the company was using browsing data partly derived from cookies placed before any expression of will by the internet user. 157. Furthermore, regarding the scope of the processing, the restricted panel notes that the breach is all the more serious as the processing in question, which aims to display personalized advertisements, is carried out on a very large scale and inherently has a massive and intrusive nature. 158. It recalls that for the displayed advertisements to be relevant, the company must collect large amounts of data related to the browsing habits of internet users in order to establish an accurate picture of their consumption habits, preferences, or current concerns. 159. Thus, each visit to an advertiser's or publisher's site, each click on a product, or each purchase made by an internet user is recorded by the company and then analyzed for advertising purposes. In this regard, the company claims on its website to collect 35 billion events per day related to browsing and purchases worldwide. Moreover, the company shares and receives data from its partners, allowing it to better identify each internet user or to establish a link between the different devices and browsers used by the same internet user. 160. The restricted panel notes that, when taken in isolation, each piece of data collected by the company has a low identifying value; however, when combined, they are likely to reveal with significant precision many aspects of individuals' private lives, including their gender, age, and consumption habits, that is to say, their preferences, thus giving the processing in question a massive and intrusive character. 161. Consequently, the result of the combination of these data significantly enhances the massive and intrusive nature of the processing in question and makes it all the more necessary that it be implemented in strict compliance with the applicable rules, particularly those surrounding individuals' choices regarding the use of their data. 162. Similarly, the restricted panel recalls that the transformation of raw browsing data into actionable information constitutes the core activity of the company. Therefore, it must be even more capable of ensuring that the personal data it processes complies with the applicable regulations. 163. Regarding the number of individuals

affected by the processing in question, the restricted panel notes that the company claims to have data related to approximately 370 million user identifiers across the European Union, including about 50 million identifiers in France alone. While a single individual may correspond to multiple identifiers, these figures reveal the substantial amount of data collected by the company. 164. Concerning the breach related to informing individuals, the restricted panel emphasizes that it has led to a loss of control for internet users over their data, as the company did not provide them with complete and understandable information. 165. Regarding the breaches related to the exercise of rights of access, withdrawal of consent, and erasure, the restricted panel highlights their structural nature and severity, as the measures deployed by the company not only lead to individuals' requests being incorrectly processed but also to them legitimately believing that their request has been respected. 166. It thus recalls that at the time of the findings, individuals who had made a request for access were not provided with the data contained in two tables of the company's database. 167. The restricted panel also recalls that the company's consideration of a

****Request for Deletion**** has the sole effect of stopping the display of personalized advertisements, while the company continues to retain the data of the person making the request and even uses it for other purposes.

168. Regarding the failure to provide for an agreement between the joint controllers of processing, the restricted formation considers that the lack of more precise regulation of the processing carried out jointly with other actors deprived the individuals concerned of the full protection of their personal data offered by the GDPR.

169. Secondly, the restricted formation believes that it is appropriate to apply the criterion set out in paragraph k) of Article 83, paragraph 2, of the GDPR concerning the financial benefits obtained due to the breach.

170. It recalls that the company's business model relies exclusively on its ability to display the most relevant advertisements to internet users to promote the products of its advertising clients, and therefore on its capacity to collect and process a vast amount of personal data.

171. However, it emerges from the present procedure that this collection and processing are carried out in violation of the requirements of the GDPR and the rights of the individuals concerned, as the company is accused of being unable to demonstrate that these individuals have given their consent to the processing of their data, and it is established, in certain cases, that the company processed data for which the individuals concerned had not consented or had not given valid consent.

172. Thus, the personal data collected and processed without valid consent from the individuals allowed the company to unduly increase the number of individuals concerned by its processing and therefore its financial revenues.

173. The restricted formation adds that the company also gained a financial advantage by failing to delete the data, continuing to use the data that is not deleted for the improvement of its technologies, which contributes to its competitiveness in the targeted advertising market.

174. Consequently, the restricted formation considers that an administrative fine should be imposed for the breaches of Articles 7, 12, 13, 15, 17, and 26 of the GDPR.

175. Secondly, regarding the determination of the amount of the fine, the restricted formation recalls that under the provisions of Article 20, paragraph III, of the Data Protection Act and Article 83 of the GDPR, the company is liable, in light of the aforementioned breaches, to a financial penalty of a maximum amount of 20 million euros or 4% of its total global revenue from the previous financial year, which was 1.9 billion euros in 2022, with the higher amount being retained.

176. Therefore, in view of the company's responsibility, its financial capabilities, and the relevant criteria of Article 83, paragraph 2, of the Regulation mentioned above, the restricted formation believes that a fine of forty million euros is justified.

177. It notes that while this amount constitutes nearly 2% of the company's global revenue, it remains

below the legal ceiling of 4% provided for in Article 83, paragraph 5 of the GDPR and Article 20, paragraph III, 7°) of the Data Protection Act.

178. Furthermore, the restricted formation recalls that the amount of the fine may exceed the profit generated by the data controller, to the extent that this would be necessary to ensure the deterrent nature of the sanction (see, in this sense, CE, March 1, 2021, Société Futura Internationale, No. 437808, pt. 6).

****B. On the Publicity of the Decision****

179. The company requests the restricted formation not to make its decision public.

180. The restricted formation, on the contrary, considers that the publicity of this decision is justified in light of the seriousness of the breaches in question, the scope of the processing, and the number of individuals concerned.

181. It also notes that this measure will inform the individuals concerned of the existence of the processing implemented by the company and the fact that it may have processed their data without their knowledge, even despite their lack of consent. This information will allow them, if necessary, to assert their rights under the Data Protection Act with the company.

182. Finally, it believes that this measure is proportionate since the decision will no longer specifically identify the company after a period of two years from its publication.

****FOR THESE REASONS****

The restricted formation of the CNIL, after deliberation, decides to:

- impose an administrative fine on the company CRITEO SA in the amount of forty million euros (€40,000,000) for the breaches of Articles 7, 12, 13, 15, 17, and 26 of the GDPR;
- make its deliberation public on the CNIL website and on the Légifrance website, which will no longer allow for the specific identification of the company after a period of two years from its publication.

The President
Alexandre LINDEN

This decision may be subject to appeal before the Council of State within two months from its notification.